

NYC / AI AGENT SECURITY SUMMIT

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

The wall is not the interesting part

A sandbox is a wall.

A working agent needs doors.

credentials mounts allowed endpoint done

You cannot weld them shut. So which layer can refuse while it is still being helpful?

Door 1 / inherited credentials

```
GET /projects/other/private
```

```
runner token      200
```

```
task token       403
```

```
its own input    200
```

Short-lived credential projection. Scope is the lock.

Recorded Linux isolation run + factory

Door 2 / dangerous mounts

```
write /shared/next-job.json
```

writable bind	host file changes
scoped bind	write denied
/output	still works

Capability-scoped filesystems. Tomorrow's snapshot is already in the room.

Recorded Linux isolation run + factory

Door 3 / allowed endpoint

same host, wrong mailbox

team/reports intended

other/uploads gets the private fixture

Real process isolation. The worker does not address the envelope.

Recorded Linux isolation run + factory

Door 4 / verifier tampering

checker.py	hash unchanged
expected.json	worker-written
CI / merge	PASS

GET /admin (no cookie)	401 required
shipped	200

You hired it to get to done. Done is a door.

Recorded Linux isolation run + factory

Close each door where it can actually refuse

Door

Layer from the abstract

Inherited credentials Short-lived credential projection

Dangerous mounts Capability-scoped filesystems

Allowed endpoint Real process isolation

Verifier tampering Tamper-evident execution history

History catches a rewrite. Freeze and grade off the worker so /admin stays 401.

Recorded Linux isolation run + factory

Four boundaries. Your deployment.

Door Ask Monday

Identity Whose badge, how small, how brief?

Files What can it change, including tomorrow?

Endpoint Who gets the envelope, what is inside?

Done Who is allowed to say these bytes are true?

Refuse outside the worker. Then prove the real ticket still completes.

THE WALL HELD. THE DOORS DID NOT.

Who gave this process the authority?

github.com/zozo123/nyc-talk

Four doors. Four locks. Try them on your box.

Appendix / Steal the repo

```
make factory      # freeze, judge, gate  
make demo         # Linux isolation lab  
make deck         # this PDF
```

29 lab checks passed, 6 factory checks passed.

Appendix / What this is not

Not a vendor 0-day. Not a kernel talk. Not last decade's least privilege with extra slides.

Agents finish tickets. The four doors are the job. That is why the title works.

Twenty-nine checks are not twenty-nine CVEs.

Appendix / You are here

github.com/zozo123/nyc-talk

Script, slides, recorded results

AI Agent Security Summit, NYC